

YieldFi Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Immeas

Jorge

April 24, 2025

Contents

1 About Cyfrin **2**

2 About This Document **2**

3 Disclaimer **2**

4 Copyright and License **2**

5 Audit Overview **3**

6 Audit Scope **4**

7 Risk Classification **4**

8 Protocol Summary **4**

8.1 Key Components 4

9 Attestation **5**

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for YieldFi on YieldFi. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated April 24, 2025, was delivered to YieldFi, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from YieldFi or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 8 days, the Cyfrin team conducted an audit on the YieldFi code provided by YieldFi. The findings consist of 2 Critical, 1 High, 5 Medium & 7 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	YieldFi
Repository	contracts
Commit	40caad6c6062...
Audit Timeline	Apr 1st - Apr 10th, 2025
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	2	2	0
High Risk	1	1	0
Medium Risk	5	5	0
Low Risk	7	7	0
Informational	10	9	1
Gas Optimizations	4	3	1
Total	29	27	2

6 Audit Scope

```
contracts/administrator/Access.sol
contracts/administrator/Administrator.sol
contracts/bridge/ccip/BridgeCCIP.sol
contracts/bridge/Bridge.sol
contracts/bridge/BridgeLR.sol
contracts/bridge/BridgeMB.sol
contracts/core/l1/LockBox.sol
contracts/core/l1/Yield.sol
contracts/core/tokens/YToken.sol
contracts/core/tokens/YTokenL2.sol
contracts/core/BondReceipt.sol
contracts/core/Manager.sol
contracts/core/MPC.sol
contracts/core/PerpetualBond.sol
contracts/core/Receipt.sol
contracts/core/SwapHelper.sol
contracts/libs/Codec.sol
contracts/libs/Common.sol
contracts/libs/Constants.sol
contracts/libs/Helpers.sol
```

During the audit, one extra PR and a commit, d082bfd, with new features were also reviewed.

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

YieldFi is an asset management protocol that issues yield-bearing ERC-4626 vault tokens (`YTokens`), which represent a user's share of the trading profits and yield generated by the protocol. This audit covered several new features, including integration with Chainlink CCIP for cross-chain messaging (in addition to the existing LayerZero integration), a new ERC20 token called `PerpetualBond` (a bond token that continuously generates yield while held), and a new two-step withdrawal process enabled by the `Manager` contract.

Another new feature allows users to deposit using any supported token through a two-step deposit process, also handled by the `Manager` contract. Currently, only stablecoins such as USDC, USDT and DAI are supported. However, in the near future, YieldFi plans to add support for ETH, BTC and various derivatives as assets within the `YToken` vaults.

8.1 Key Components

- **YTokens:** ERC-4626 vault tokens that track users' share of protocol yield and profits.
- **Manager:** facilitates two-step deposits and withdrawals, and applies protocol rules around minimum amounts and yield processing.
- **Off-chain service:** executes orders, performs token conversions and handles pricing logic.
- **PerpetualBond:** a bond-like ERC20 token that continuously accrues yield while held.

9 Attestation

Cyfrin attests that it performed a security review of the YieldFi code provided by YieldFi.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2025-04-24-cyfrin-yieldfi-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to YieldFi has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=cc9850f45ec6fc96aceffb78befdb1cffa7c35164955ac2cc7456a974db81624
F=2025-04-24-cyfrin-yieldfi-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.